权限场景测试

酒店房态与入住协同 MVP · 结论权与执行权分离：谁能改房态

文档编号：HRSC-TEST-04

被测系统：src/room-status-mvp（v1.0.0）

本场景用例：12 条，通过 12 条

证据：接口实测 + 页面实拍（Edge headless）

编制日期：2026 年 11 月 6 日

目　录

一、场景定义与测试目标 3

二、判定标准 4

三、测试环境与数据 5

四、测试过程 6

五、过程截图 7

六、结论 10

一、场景定义与测试目标

本场景属于五类场景中的「权限」类。之所以单独成册，是因为这一类问题在真实门店里不是「会不会发生」，而是「发生了几次、有没有被记录」。以下四点是要验证的对象：

- 验证未登录访问业务接口一律 401；
- 验证四个岗位越权时返回 403 + 业务码 40301，且提示「请交接给对应岗位」；
- 验证同一动作在不同房态下的拦截顺序（先闸门、后岗位）不会互相掩盖；
- 验证页面级访问控制（前台访问 /admin 被重定向回 /staff）。

二、判定标准

表 2-1　权限场景判定标准

判定项	通过标准
未登录	401 + 40102，不泄露任何业务数据
越权	403 + 40301，提示中写明该动作归属岗位
岗位内合法	本岗位动作返回 200（如客房开始清扫）
页面级	前台访问 /admin 返回 307 并跳回 /staff
审计	运营可读审计日志与阈值；其他岗位 403

三、测试环境与数据

表 3-1　环境与数据

项	说明
实例	:8103 基线（干净数据 24 间房）　/　:8101 截图实例
账号	front / Front@123　house / House@123　qa / Qa@123　admin / Admin@123
数据复位	用例按状态动态探测房间并沿状态机驱动到所需状态，不写死房号，可反复执行
证据形式	接口矩阵（状态码 + 业务码 + 耗时）与页面实拍（含接口证据面板）

四、测试过程

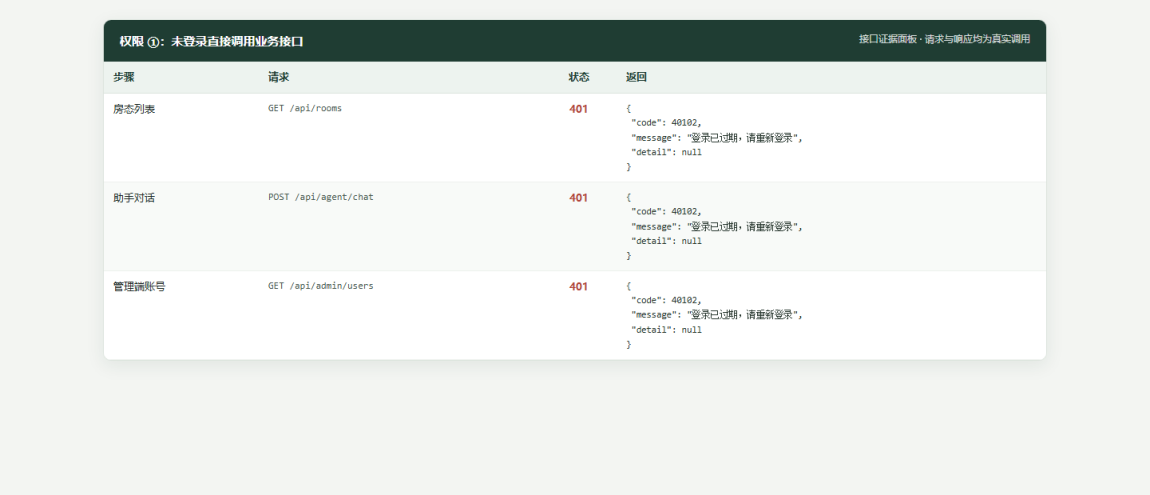
下表按实际操作顺序记录：每一步都在真实实例上执行，请求列给出实际接口，实际列记录系统真实返回（不是预期值的复述）。

表 4-1　权限场景执行过程

步	操作	接口 / 路径	预期	实际结果	结论
1	未登录调用 /api/rooms、/api/agent/chat、/api/admin/users	GET / POST	全部 401	三条均为 401 + 40102	通过
2	前台调用查房通过	POST pass_inspection（front）	403 + 40301	403，「「查房通过」不在当前岗位职责内，请交接给对应岗位」	通过
3	前台调用提交已清扫	POST finish_cleaning（front）	403 + 40301	403，同上	通过
4	前台读管理端账号列表	GET /api/admin/users	403	403，该操作仅限运营管理	通过
5	质检办入住	POST checkin（qa）	403 + 40301	403，「「办理入住」不在当前岗位职责内」	通过
6	质检改知识库	POST /api/kb/docs（qa）	403	403，该操作仅限运营管理	通过
7	质检改运行阈值	PUT /api/admin/settings（qa）	403	403	通过
8	客房办入住	POST checkin（house）	403 + 40301（房态可售时）	403；若房态不可售则先被闸门拦下返回 40003（见 图 5-4）	通过
9	客房开始清扫	POST start_cleaning（house）	200	200，to_state=cleaning	通过
10	客房查审计	GET /api/admin/audit（house）	403	403	通过
11	前台访问 /admin 页面	GET /admin	307 → /staff	307，Location=/staff	通过
12	运营读审计与阈值	GET /api/admin/audit、/settings	200	200，审计 61 条	通过

五、过程截图

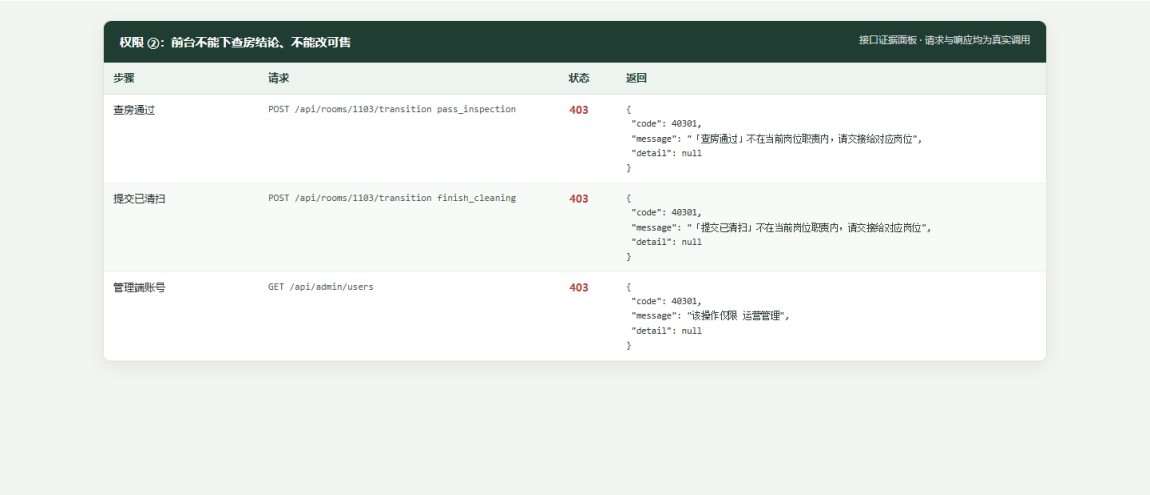
以下截图由 Edge headless 驱动真实浏览器拍摄；带「接口证据面板」的图，其请求、状态码与返回体均为当时真实调用结果，未做任何拼接或美化。



权限 ①：未登录直接调用业务接口　　接口证据面板 · 请求与响应均为真实调用

步骤	请求	状态	返回
房态列表	GET /api/rooms	401	{ "code": 40102, "message": "登录已过期，请重新登录", "detail": null }
助手对话	POST /api/agent/chat	401	{ "code": 40102, "message": "登录已过期，请重新登录", "detail": null }
管理端账号	GET /api/admin/users	401	{ "code": 40102, "message": "登录已过期，请重新登录", "detail": null }

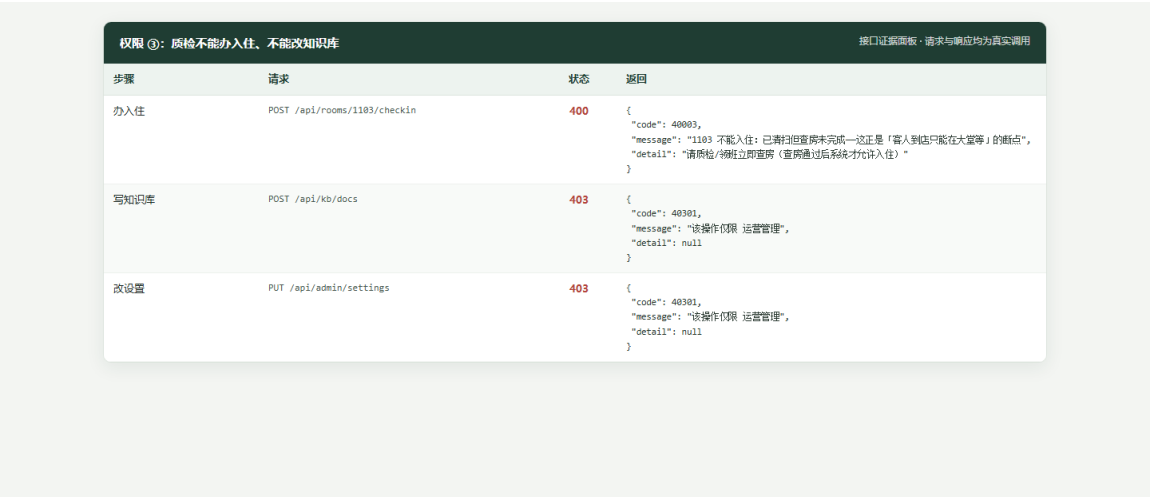
图 5-1　第 1 步：未登录调用房态列表、助手对话、管理端账号，三条全部 401 + 40102「登录已过期，请重新登录」



权限 ②：前台不能下查房结论、不能改可售　　接口证据面板 · 请求与响应均为真实调用

步骤	请求	状态	返回
查房通过	POST /api/rooms/1103/transition pass_inspection	403	{ "code": 40301, "message": "「查房通过」不在当前岗位职责内，请交接给对应岗位", "detail": null }
提交已清扫	POST /api/rooms/1103/transition finish_cleaning	403	{ "code": 40301, "message": "「提交已清扫」不在当前岗位职责内，请交接给对应岗位", "detail": null }
管理端账号	GET /api/admin/users	403	{ "code": 40301, "message": "该操作仅限 运营管理", "detail": null }

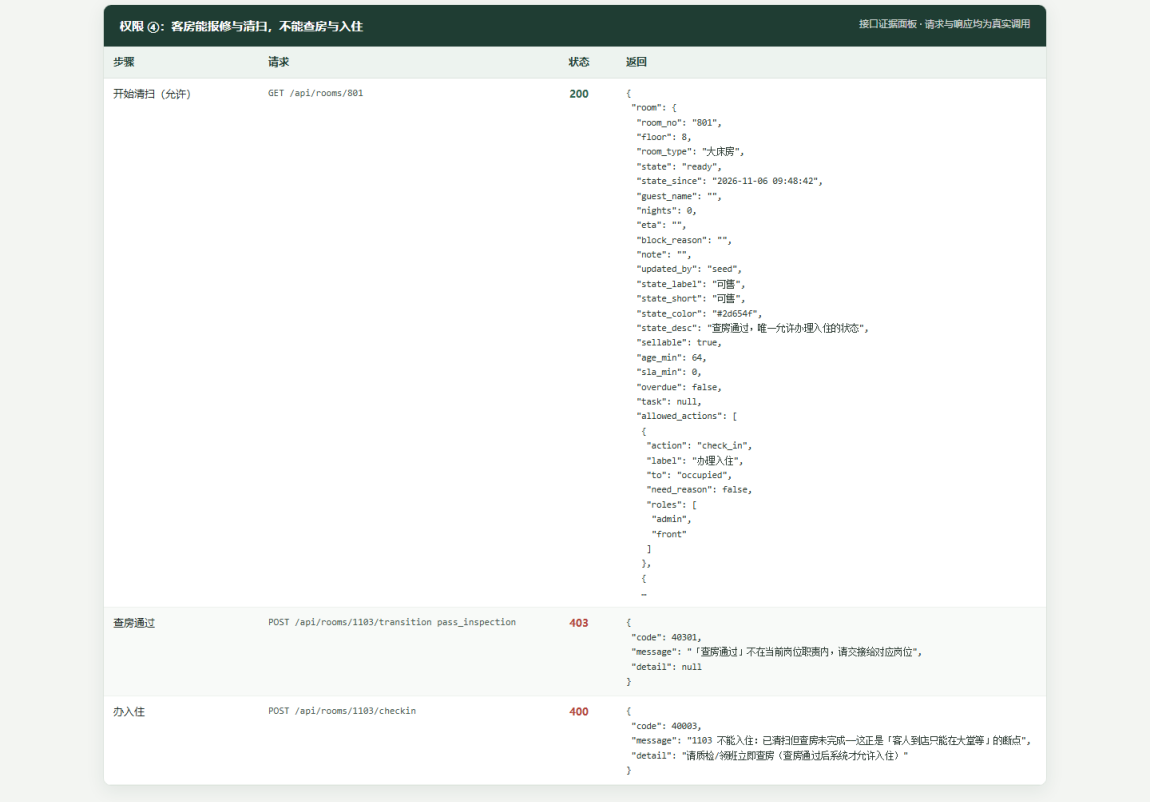
图 5-2　第 2–4 步：前台调用查房通过、提交已清扫、读账号列表，三条全部 403 + 40301，提示写明「请交接给对应岗位」与「该操作仅限运营管理」



权限 ③：质检不能办入住、不能改知识库　　接口证据面板 · 请求与响应均为真实调用

步骤	请求	状态	返回
办入住	POST /api/rooms/1103/checkin	400	{ "code": 40003, "message": "1103 不能入住：已清扫但查房未完成——这正是「客人到店只能在大堂等」的断点", "detail": "请质检/领班立即查房（查房通过后系统才允许入住）" }
写知识库	POST /api/kb/docs	403	{ "code": 40301, "message": "该操作仅限 运营管理", "detail": null }
改设置	PUT /api/admin/settings	403	{ "code": 40301, "message": "该操作仅限 运营管理", "detail": null }

图 5-3　第 5–7 步：质检调用办入住（40301）、写知识库（403）、改设置（403）



权限 ④：客房能报修与清扫，不能查房与入住　　接口证据面板 · 请求与响应均为真实调用

步骤	请求	状态	返回
开始清扫（允许）	GET /api/rooms/801	200	{ "room": { "room_no": "801", "floor": 8, "room_type": "大床房", "state": "ready", "state_since": "2026-11-06 09:48:42", "guest_name": "", "nights": 0, "eta": "", "block_reason": "", "note": "", "updated_by": "seed", "state_label": "可售", "state_short": "可售", "state_color": "#2d654f", "state_desc": "查房通过，唯一允许办理入住的状态", "sellable": true, "age_min": 64, "sla_min": 0, "overdue": false, "task": null, "allowed_actions": [{ "action": "check_in", "label": "办理入住", "to": "occupied", "need_reason": false, "roles": ["admin", "front"] }, { …
查房通过	POST /api/rooms/1103/transition pass_inspection	403	{ "code": 40301, "message": "「查房通过」不在当前岗位职责内，请交接给对应岗位", "detail": null }
办入住	POST /api/rooms/1103/checkin	400	{ "code": 40003, "message": "1103 不能入住：已清扫但查房未完成——这正是「客人到店只能在大堂等」的断点", "detail": "请质检/领班立即查房（查房通过后系统才允许入住）" }

图 5-4　第 8–9 步：客房能读房（200，含 allowed_actions 与各自所需岗位），但查房通过被拒 403；办入住被闸门先拦，返回 40003 并给出责任岗位

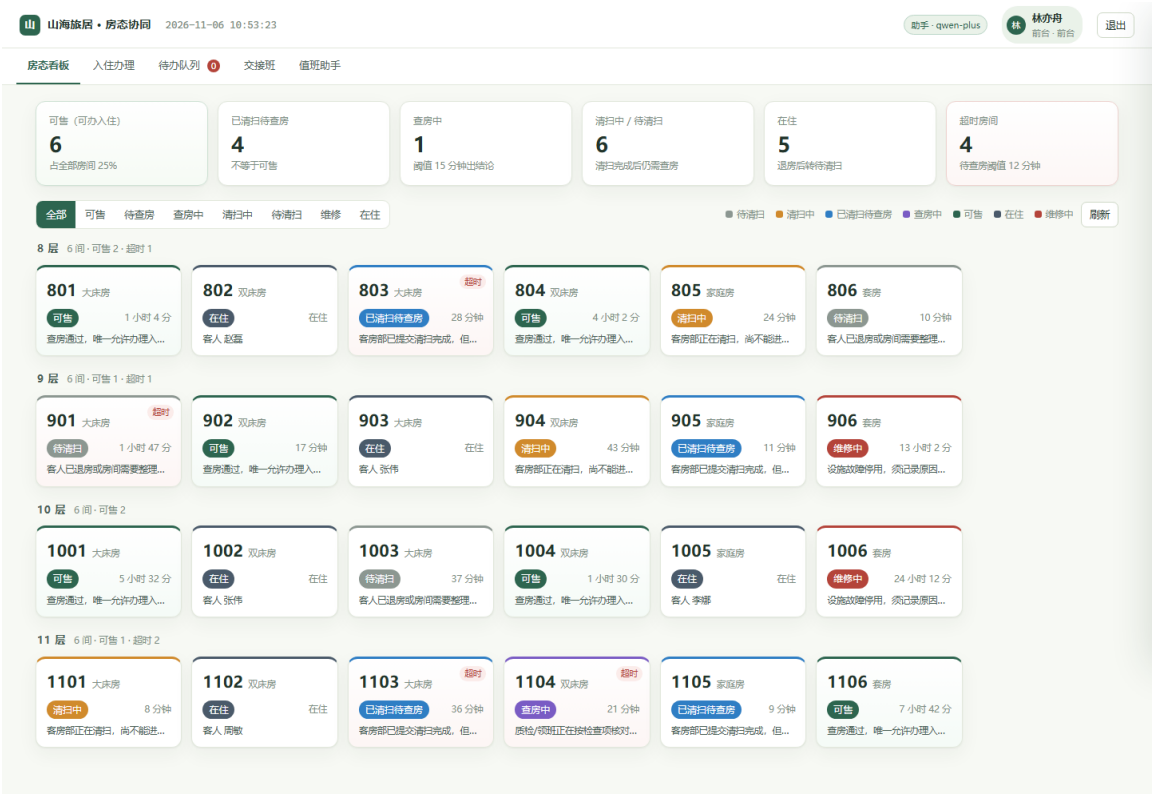


图 5-5　第 11 步：前台直接访问 /admin，被 307 重定向回 /staff，只能看到自己的岗位工作台

六、结论

（1）12 条权限用例全部通过：未登录 401、越权 403 + 40301、页面级 307，三层都有效；

（2）第 8 步暴露了拦截顺序：办入住先过闸门（房态不可售直接 40003），再过岗位守卫（40301）。顺序不同导致返回码不同，但两者都是「拒绝」，且提示都能指导下一步——这是防御纵深，不是缺陷；

（3）修复 D1 之前，这些越权请求返回的是 400，与「参数填错」无法区分；修复后统一为 403，值班人员能一眼分清是权限问题还是表单问题。

说明 本场景 12 条用例全部通过；逐条记录见《测试方案》附录 A，整体 53 条用例 100% 通过。